

SGSI-UNCP

Plantilla de Plan de Auditoría Interna del SGSI

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Plantilla de Plan de Auditoría Interna del SGSI
 - 1.1 Objetivos de la Auditoría
 - 1.2 Alcance de la Auditoría
 - 1.3 Criterios de Auditoría
 - 1.4 Metodología de Auditoría (según P-SGSI-09)
 - 1.5 Equipo Auditor
 - 1.6 Cronograma de Actividades (Agenda)
 - 1.7 Recursos Necesarios
 - 1.8 Confidencialidad e Independencia

1. Plantilla de Plan de Auditoría Interna del SGSI

Organización: Universidad Nacional del Centro del Perú (UNCP) **Referencia:** ISO/IEC 27001:2022 (Cláusula 9.2) / P-SGSI-09 (Metodología de Auditoría Basada en Riesgos) **ID de Auditoría:** AUD-2026-001 **Tipo de Auditoría:** [x] Interna [] Externa [] Pre-certificación [] Certificación **Nivel de Riesgo de la Auditoría:** [x] Medio [] Alto [] Bajo

1.1. Objetivos de la Auditoría

- Verificar el cumplimiento del SGSI con los requisitos de la norma ISO/IEC 27001:2022.
- Evaluar la eficacia y madurez de los controles implementados según la Declaración de Aplicabilidad (D-SGSI-05).
- Identificar no conformidades, observaciones y oportunidades de mejora para la revisión por la dirección.
- Determinar la capacidad del SGSI para prepararse para la certificación prevista en 2027.
- Verificar la implementación de acciones correctivas y el avance de los planes de tratamiento de riesgos.

1.2. Alcance de la Auditoría

1.2.1. Procesos y Unidades a Auditar

Auditoría total del SGSI en la sede central de la UNCP (Av. Mariscal Castilla N.º 3909, El Tambo, Huancayo), cubriendo:

- **Rectorado / CGD:** Compromiso de liderazgo, revisión de políticas.
- **OTI:** Gestión de activos, controles técnicos, operaciones de TI, seguridad en redes.
- **Oficina de Seguridad y Confianza Digital:** Gestión de riesgos, SoA, capacitación, métricas.
- **Abastecimiento / DGA:** Gestión de proveedores, contratos.
- **Recursos Humanos:** Inducción, confidencialidad, competencia.
- **Infraestructura física:** Data Center principal (piso 3), sala de servidores FIIS, sala de comunicaciones DGA.

1.2.2. Exclusiones (si aplica)

- Sede filial de Satipo (no cuenta con SGSI implementado; se incorporará en alcance 2027).
- Laboratorios de investigación no conectados a la red corporativa (aislados físicamente).

1.2.3. Período Cubierto

Desde la implementación inicial del SGSI (enero 2026) hasta el corte de la auditoría (mayo 2026).

1.3. Criterios de Auditoría

- Norma ISO/IEC 27001:2022 (Cláusulas 4–10).
- Controles del Anexo A según la Declaración de Aplicabilidad (D-SGSI-05).
- Políticas y procedimientos internos del SGSI-UNCP.
- Ley N.º 29733 (Protección de Datos Personales) y su reglamento D.S. 016-2024-JUS.
- Decreto Legislativo N.º 1412 (Gobierno Digital) y normas complementarias.
- Norma NIST SP 800-63B (Autenticación) y NIST SP 800-88 (Eliminación segura) según aplique.

1.4. Metodología de Auditoría (según P-SGSI-09)

1.4.1. Técnicas de Recolección

Técnica	Aplica en
[x] Entrevistas	Rectorado, OTI, DGA, RRHH, Oficial de Seguridad
[x] Revisión documental	Todos los documentos del SGSI (D-SGSI, P-SGSI, R-SGSI, POL-SGSI)
[x] Observación directa	Data Center, sala de servidores FIIS, puesto de trabajo
[x] Análisis técnico	Configuración de firewall, Active Directory, logs Huawei Cloud CBR
[x] Muestreo estadístico	Registros de acceso, solicitudes de cambio, incidentes reportados
[] Recorrido (Walkthrough)	No aplica para esta auditoría
[x] Simulación / Prueba	Verificación de backups mediante solicitud de restauración

1.4.2. Tamaño de Muestra

Población	Tamaño	Método de Muestreo
Solicitudes de acceso (ene–may 2026)	25	Aleatorio estratificado por tipo (alta/baja/cambio)
Incidentes reportados (2026)	10	Por juicio (todos los críticos + muestra de medios/bajos)
Cambios en TI (ene–may 2026)	5	Censo completo (todos los registrados)
Cuentas de proveedores activas	8	Censo completo
Equipos inventariados (R-SGSI-01)	12	Aleatorio simple (50 % de los 24 activos)

1.5. Equipo Auditor

Rol	Nombre	Certificaciones
Auditor Líder	Mg. Carlos Ramos Quispe	ISO 27001:2022 LA, CISA
Auditor Técnico	Ing. María Rojas Llanos	CISSP, AWS Certified Security
Auditor de Soporte	Bach. Luis Torres Miranda	ISO 27001:2022 IA
Observadores / Expertos	Ing. Luis Castillo Gutiérrez (Oficial Seguridad)	ISO 27001 LA

1.6. Cronograma de Actividades (Agenda)

Día	Hora	Proceso / Área	Cláusulas / Controles	Auditado (Responsable)	Auditor
20/05	08:30–09:00	Reunión de Apertura	–	CGD	Equipo
20/05	09:00–11:00	Contexto y Liderazgo	Cl. 4, 5	Rector / DGA	Líder
20/05	11:00–13:00	Planificación y Riesgos	Cl. 6, D-SGSI-04, R-SGSI-02	Oficial de Seguridad	Líder
20/05	14:00–16:00	Soporte y Operaciones	Cl. 7, P-SGSI-03, P-SGSI-04, P-SGSI-06, P-SGSI-07	OTI	Técnico
20/05	16:00–17:00	Evaluación y Mejora	Cl. 9, 10, P-SGSI-09, R-SGSI-03	Oficial de Seguridad	Líder
20/05	17:00–17:30	Reunión de Cierre (Día 1)	–	CGD	Equipo
21/05	08:30–12:00	Controles Técnicos (Anexo A)	A.5.15, A.5.16, A.5.17, A.5.24, A.8.25, A.8.26	OTI (Infraestructura / Desarrollo)	Técnico

Día	Hora	Proceso / Área	Cláusulas / Controles	Auditado (Responsable)	Auditor
21/05	12:00–13:00	Seguridad Física	A.7.1–A.7.14, POL-SGSI-07	OTI / DGA	Técnico
21/05	14:00–15:00	Proveedores y Terceros	A.5.19–A.5.23, POL-SGSI-04, P-SGSI-06	DGA / Logística	Líder
21/05	15:00–16:00	Revisión de Hallazgos (Equipo Auditor)	–	N/A	Equipo
21/05	16:00–17:00	Reunión de Cierre y Presentación de Hallazgos	–	CGD	Equipo

1.7. Recursos Necesarios

- Acceso a la documentación del SGSI (carpeta compartida en Microsoft Teams).
- Acceso a evidencias técnicas: logs de firewall (FortiGate), consola Huawei Cloud, Active Directory, listas de acceso de ERP ADESA.
- Sala de reuniones (Sala de Consejo Universitario, piso 2) y plataforma Microsoft Teams para sesiones virtuales.
- Equipo de cómputo portátil (uno por auditor).
- Acceso físico al Data Center (piso 3), sala de servidores FIIS y oficinas administrativas.

1.8. Confidencialidad e Independencia

Los miembros del equipo auditor declaran su independencia respecto a las áreas auditadas y se comprometen a mantener la confidencialidad de la información obtenida durante el proceso, conforme a la POL-SGSI-02 y la Ley N° 29733.

Elaborado por:

Mg. Carlos Ramos Quispe Auditor Líder

Aprobado por:

Ing. Luis Castillo Gutierrez Oficial de Seguridad y Confianza Digital

Fecha de Aprobación:

05/05/2026